TEK1314 · KEAMANAN SIBER · CHECKPOINT MINGGU 9

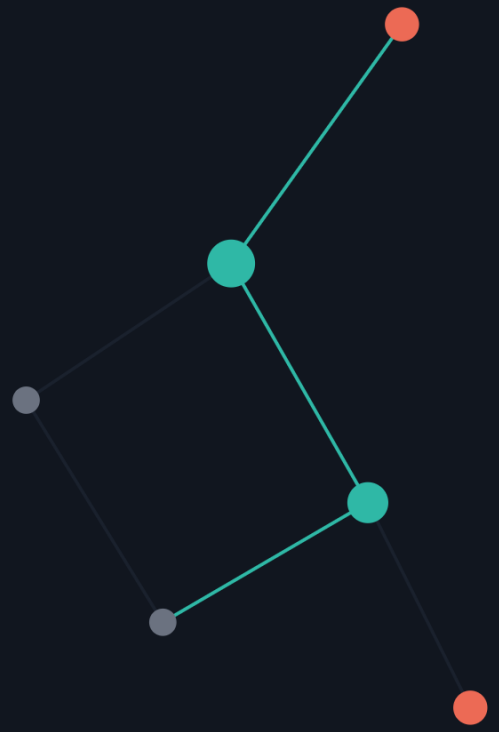
Simulated SOC Engagement — KABITA

Mengamankan infrastruktur backend sistem IoT pencatat bobot kambing berbasis RFID — Kelompok 4

LEAD
Olan Elrai Ramotan Sibagariang
J0404241158

BLUE TEAM
Anggi Permana Putra
J0404241154

RED TEAM
Raka Syauqi Ferdian — J0404241112
Muhammad Zidan — J0404241173



Fase 1 → Fase 2

01 — KONTEKS PROYEK

Apa itu KABITA?

Alat Genggam Peternak

Membaca tanda telinga (RFID) setiap kambing, lalu mencatat bobotnya langsung di lapangan — tanpa buku catatan manual.

Yang Diamankan Tim SOC

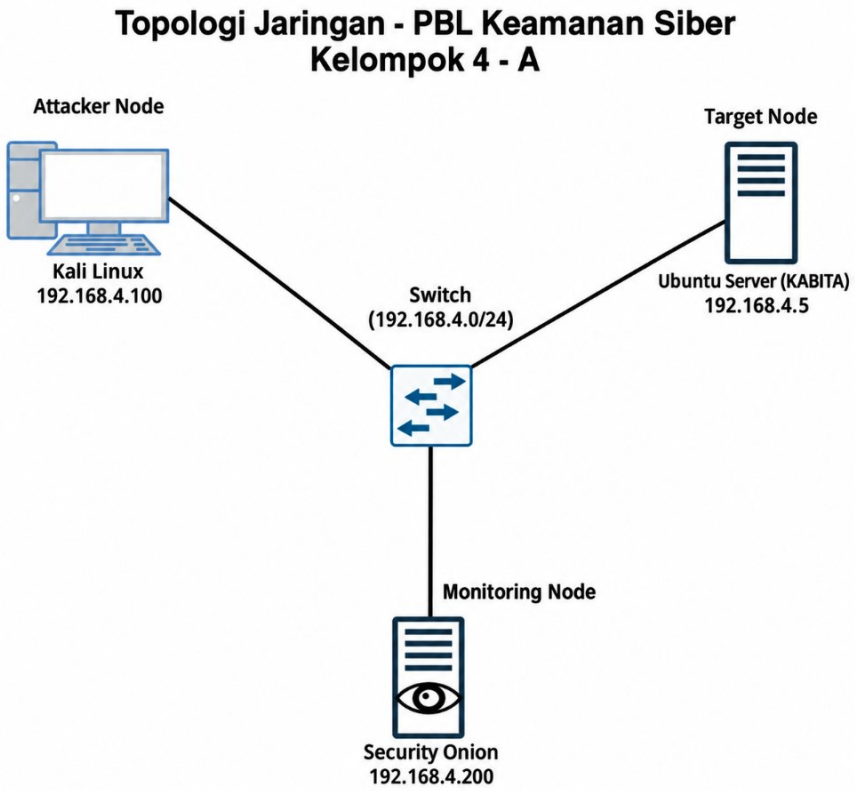
Backend: server data, dashboard web, API gateway — catatan tersimpan otomatis & sistem memperkirakan laju pertambahan berat.

Deklarasi Tech Stack & Replikasi

Komponen	Proyek Asli	Target Node (Replika)
Sistem Operasi	—	Ubuntu 26.04 LTS
Database	PostgreSQL	PostgreSQL 16, localhost-only
Backend API	Golang	Golang REST, port 8080
Protokol sensor	MQTT	MQTT (broker Mosquitto, auth wajib) + HTTP REST fallback
Dashboard	Vue/React	Build statis via Nginx

TERIMPLEMENTASI MQTT & HTTP REST satu jalur validasi (processReading) — subscriber Mosquitto aktif & teruji end-to-end

Arsitektur Simulasi



04 — HARDENING

Progres Hardening & Baseline

A. Access & Auth — 2/2

- SSH key-based auth, root & password login off
- Port custom 2222 + fail2ban rate-limit

B. Service & Surface — 3/3

- UFW whitelist 2222/80/443/1883, default deny
- ModemManager off, unattended-upgrades aktif
- PostgreSQL listen hanya localhost; MQTT 1883 ke LAN wajib auth

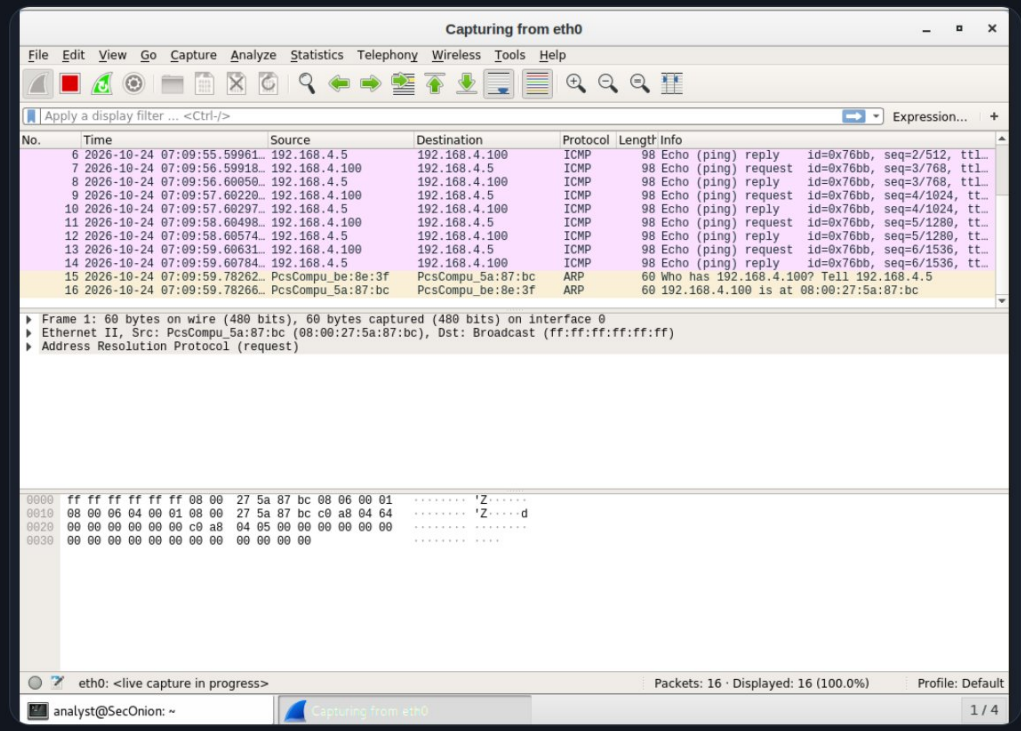
C. Data & App — 3/3

- Kredensial via .env, mode 600
- Validasi input API (tag_rfid, berat, id)
- DB least-privilege + query logging

05 — LIVE DEMO

Security Onion memantau traffic lab secara aktif

- Baseline: *ping test* dari Attacker Node ke Target Node
- Disadap live via Wireshark pada interface monitor Security Onion
- ICMP Echo Request/Reply & ARP resolve antara 192.168.4.100 ↔ 192.168.4.5 terekam
- Belum serangan sungguhan — baru tahap monitoring normal



Wireshark — capture langsung dari Security Onion

06 — ATTACK PLAN

Attack Plan Fase 2

Kategori	Skenario	Tools
Reconnaissance	Port/service scan + OS fingerprinting	nmap -sV -O -p-
Exploitation / Akses	Brute-force login SSH (port 2222)	Hydra + wordlist
Web/API/Protokol IoT	SQL injection pada endpoint riwayat kambing	sqlmap / manual
Web/API/Protokol IoT	Publish MQTT tanpa kredensial (harus ditolak)	mosquitto_pub (tanpa -u/-P)
Web/API/Protokol IoT	Publish MQTT dengan kredensial bocor — payload palsu masuk bobot_log	mosquitto_pub -u kabita_device -P <bocor>

5 skenario, 3 kategori berbeda, tanpa DoS. Broker MQTT tidak punya rate-limit — temuan untuk Purple Team Loop.

07 — PENUTUP

Kendala & Pembelajaran

Hambatan

Captive portal kampus memblokir *apt install* lewat default-route ganda (NAT + Bridge); Nginx *proxy_pass* salah strip prefix /api/; paste SQL multi-baris tertelan perintah psql \c; mosquitto gagal start setelah reboot karena *password_file* tidak terbaca user mosquitto; .env sempat diisi ulang dengan password DB yang salah.

Pembelajaran

Uji tiap layer satu per satu (routing → service → aplikasi); baca pesan error sampai detail sebelum berasumsi; pisahkan setup kredensial dari eksekusi script interaktif; uji ulang lewat reboot penuh untuk menangkap bug urutan start-up (MQTT subscriber terbukti pulih sendiri tanpa restart backend); .env & role database harus diubah bersamaan, tidak boleh sendiri-sendiri.